DOCUMENTAÇÃO COMPLETA

Sistema Web / CRM

Arquitetura, Processos, Tecnologias e Manutenção

Versão 1.0.0	**Data** Abril / 2026
Tipo Documento Técnico	**Status** Em Produção

1. Visão Geral do Projeto

1.1 Objetivo

Este documento descreve a arquitetura completa, os processos de desenvolvimento, as tecnologias adotadas e os procedimentos de manutenção de um sistema web integrado com CRM (Customer Relationship Management). O objetivo é fornecer uma referência técnica unificada para todos os papéis envolvidos no ciclo de vida do produto: desde o designer até o engenheiro de DevOps.

1.2 Escopo do Sistema

O sistema compreende as seguintes grandes áreas funcionais:

- Site institucional / portal público com páginas otimizadas para SEO
- Módulo CRM: gestão de clientes, leads, oportunidades e contatos
- Painel administrativo (backoffice) para operadores e gestores
- APIs REST/GraphQL para integrações externas e mobile
- Pipeline de automação de marketing e e-mails transacionais
- Infraestrutura cloud com alta disponibilidade e monitoramento

1.3 Papéis e Responsabilidades

Papel	Responsabilidades Principais
UX Designer	Pesquisa de usuários, wireframes, fluxos de navegação, testes de usabilidade
UI Designer	Design system, identidade visual, prototipagem em alta fidelidade, componentes
Arquiteto de Software	Decisões técnicas, padrões de arquitetura, revisão de código crítico
Desenvolvedor Frontend	Implementação de interfaces, integração com APIs, performance e acessibilidade
Desenvolvedor Backend	APIs, regras de negócio, integrações externas, segurança de dados
DBA	Modelagem de dados, otimização de queries, backups, replicação
DevOps / SRE	CI/CD, infraestrutura cloud, containers, monitoramento e alertas
Especialista em SEO	Estratégia de conteúdo, SEO técnico, análise de ranqueamento
Especialista em Segurança	Pentests, OWASP, LGPD, gestão de vulnerabilidades
Product Manager	Roadmap, backlog, priorização, alinhamento com stakeholders

2. Design — UX e UI

2.1 Processo de UX (User Experience)

O processo de UX precede qualquer linha de código. Ele garante que o produto resolve problemas reais dos usuários de forma eficiente e agradável.

2.1.1 Pesquisa e Descoberta

- Entrevistas com usuários-alvo (clientes e operadores do CRM)
- Análise heurística de concorrentes e sistemas existentes
- Definição de personas e jornadas de usuário (User Journey Map)
- Identificação de pontos de dor e oportunidades de melhoria

2.1.2 Wireframes e Fluxos

- Criação de wireframes de baixa fidelidade (papel ou Figma)
- Mapeamento do fluxo completo: onboarding, cadastro de leads, pipeline de vendas
- Definição da arquitetura de informação e hierarquia de navegação
- Testes de usabilidade com protótipos interativos antes do desenvolvimento

Entregáveis UX
• Documento de personas e jornadas
• Mapa de fluxos de navegação (sitemap)
• Wireframes anotados (baixa e média fidelidade)
• Relatório de testes de usabilidade
• Definição de KPIs de experiência (NPS, taxa de conclusão de tarefas)

2.2 Processo de UI (User Interface)

2.2.1 Design System

O Design System é a fundação visual do produto. Ele garante consistência em todos os componentes e acelera o desenvolvimento frontend.

Componente	Descrição
Tipografia	Fonte principal Inter (sans-serif), escala modular de tamanhos (12, 14, 16, 20, 24, 32px)
Paleta de cores	Primária (azul #2563EB), Secundária (teal #0D9E75), Neutros, Semânticas (sucesso, erro, alerta)
Espaçamento	Grade de 4px — espaçamentos sempre múltiplos de 4 (4, 8, 12, 16, 24, 32, 48px)

Componentes	Botões, inputs, cards, modais, tabelas, badges, toasts, menus, dropdowns
Ícones	Biblioteca Lucide Icons (SVG) — consistente e acessível
Breakpoints	Mobile 320px, Tablet 768px, Desktop 1280px, Wide 1440px

2.2.2 Ferramentas de Design

- Figma: design, prototipagem e Design System (componentes reutilizáveis)
- Figma Tokens: sincronização de tokens de design com o código (CSS Variables)
- Storybook: documentação interativa dos componentes UI no frontend

3. Arquitetura do Sistema

3.1 Visão Arquitetural

O sistema adota uma arquitetura em camadas desacopladas, com frontend SPA (Single Page Application) comunicando-se exclusivamente via APIs com o backend. O backend segue princípios de Clean Architecture, separando responsabilidades em camadas de domínio, aplicação e infraestrutura.

Camadas da Arquitetura
[1] Cliente (Browser / Mobile App)
↓ HTTPS / WebSocket
[2] CDN + Load Balancer (Cloudflare / AWS ALB)
↓
[3] Frontend — React SPA (Vercel / S3 + CloudFront)
↓ REST API / GraphQL
[4] API Gateway (Kong / AWS API Gateway)
↓
[5] Backend — Node.js / Python (Containers ECS / Kubernetes)
↓
[6] Camada de Dados — PostgreSQL + Redis + S3

3.2 Frontend

Tecnologia	Função
React 18 + TypeScript	Framework de UI — componentes reutilizáveis e renderização eficiente
Next.js 14	SSR/SSG para páginas públicas (SEO), roteamento e otimizações automáticas
TailwindCSS	Estilização utilitária alinhada ao Design System
React Query (TanStack)	Cache de dados do servidor, sincronização e invalidação automática
Zustand	Gerenciamento de estado global leve e previsível
React Hook Form + Zod	Formulários performáticos com validação tipada no cliente
Vitest + Testing Library	Testes unitários e de integração de componentes
Playwright	Testes end-to-end automatizados nos fluxos críticos

3.3 Backend

Tecnologia	Função
Node.js + Fastify	Servidor HTTP performático — APIs REST para o frontend e integrações
Python + FastAPI	Serviços de processamento de dados, relatórios e automações
GraphQL (Apollo Server)	API flexível para consultas complexas do painel administrativo
Bull + Redis	Filas de jobs assíncronos — e-mails, notificações, webhooks
JWT + OAuth2	Autenticação stateless e login social (Google, Microsoft)
Zod / Pydantic	Validação de entrada e saída de dados nas APIs
Prisma ORM	Acesso ao banco de dados com tipagem segura e migrations automatizadas
Jest	Testes unitários e de integração do backend

3.4 Banco de Dados e Armazenamento

Recurso	Uso
PostgreSQL 16	Banco relacional principal — clientes, leads, oportunidades, usuários
Redis 7	Cache de sessões, filas de jobs, rate limiting, pub/sub
AWS S3 / Cloudflare R2	Armazenamento de arquivos — uploads de documentos, imagens, exports
Elasticsearch	Busca full-text avançada nos registros do CRM
TimescaleDB	Extensão do Postgres para séries temporais — métricas e logs de eventos

4. Infraestrutura e DevOps

4.1 Ambientes

Ambiente	Descrição e Finalidade
Development (local)	Máquina do desenvolvedor — Docker Compose sobe todos os serviços localmente
Staging	Réplica da produção — testes de QA, validação de features antes do release
Production	Ambiente ativo — alta disponibilidade, backups automáticos, monitoramento 24/7

4.2 Pipeline de CI/CD

Todo commit na branch main dispara automaticamente o pipeline de entrega contínua, garantindo que apenas código testado e aprovado chegue à produção.

1. Desenvolvedor abre Pull Request com a feature ou correção
2. CI executa: lint, type-check, testes unitários e de integração
3. Build Docker da imagem da aplicação
4. Deploy automático no ambiente de staging
5. Testes end-to-end (Playwright) são executados no staging
6. Code review obrigatório por pelo menos um outro engenheiro
7. Merge aprovado dispara deploy em produção com zero-downtime (rolling update)
8. Smoke tests pós-deploy verificam os endpoints críticos
9. Monitoramento automático detecta regressões e aciona rollback se necessário

Stack DevOps
• Orquestração: AWS ECS Fargate ou Kubernetes (EKS)
• Containers: Docker (imagens otimizadas multi-stage build)
• CI/CD: GitHub Actions
• Infrastructure as Code: Terraform + AWS CDK
• Service Mesh: AWS App Mesh / Istio para comunicação entre serviços
• CDN: Cloudflare (assets estáticos) + AWS CloudFront (API cache)
• DNS e SSL: Cloudflare — certificados TLS automáticos

4.3 Monitoramento e Observabilidade

Ferramenta	Função
Datadog / Grafana	Dashboards de métricas de infraestrutura e aplicação em tempo real

OpenTelemetry	Rastreamento distribuído (tracing) entre todos os serviços
Loki / CloudWatch Logs	Centralização e busca de logs de todos os containers
PagerDuty / Opsgenie	Alertas e escalonamento de incidentes 24/7
Sentry	Monitoramento de erros e exceções no frontend e backend
Uptime Robot	Health checks externos — verificação de disponibilidade a cada minuto

5. Cibersegurança

5.1 Modelo de Ameaças

O sistema processa dados sensíveis de clientes e informações comerciais críticas. A postura de segurança segue os princípios de Defense in Depth e Least Privilege, com múltiplas camadas de proteção.

5.2 OWASP Top 10 — Controles Implementados

Vulnerabilidade	Controle Implementado
Injeção (SQL, NoSQL, OS)	ORM com queries parametrizadas (Prisma), validação rigorosa de inputs com Zod
Autenticação quebrada	JWT com rotação de tokens, MFA obrigatório para administradores, bloqueio por brute-force
Exposição de dados sensíveis	Criptografia em trânsito (TLS 1.3) e em repouso (AES-256), mascaramento de PII nos logs
XXE e desserialização	Parsers seguros, whitelist de tipos de conteúdo aceitos
Controle de acesso quebrado	RBAC granular, verificação de permissões em todas as rotas do backend
Configuração insegura	Secrets via AWS Secrets Manager / Vault, nenhum segredo em código ou variáveis de ambiente expostas
XSS (Cross-Site Scripting)	CSP headers, sanitização de HTML, React escapa conteúdo dinamicamente por padrão
CSRF	Tokens CSRF em formulários, SameSite=Strict nos cookies de sessão

5.3 Processos de Segurança

- SAST (Static Analysis): SonarQube analisa o código a cada commit no CI
- DAST (Dynamic Analysis): OWASP ZAP executa varreduras semanais no ambiente de staging
- Dependency scanning: Dependabot e Snyk monitoram vulnerabilidades em dependências
- Pentests externos: realizados por empresa especializada a cada 6 meses
- Bug Bounty: programa interno para reporte responsável de vulnerabilidades
- Gestão de incidentes: runbook documentado com SLA de resposta por severidade

Níveis de Severidade de Incidentes
P1 — Crítico: dados expostos, sistema indisponível | SLA resposta: 15 min | resolução: 4h
P2 — Alto: funcionalidade crítica comprometida | SLA resposta: 1h | resolução: 24h
P3 — Médio: degradação de performance ou funcionalidade menor | SLA: 4h | resolução: 72h

> P4 — Baixo: bug de baixo impacto | SLA: 1 dia útil | resolução: próxima sprint

6. SEO — Otimização para Mecanismos de Busca

6.1 SEO Técnico (Responsabilidade do Frontend e Backend)

Elemento	Implementação
Server-Side Rendering	Next.js renderiza páginas públicas no servidor — HTML indexável pelo Google
Core Web Vitals	LCP < 2.5s, FID < 100ms, CLS < 0.1 — monitorados via Google Search Console
Sitemap XML	Gerado automaticamente e submetido ao Google Search Console
robots.txt	Configura quais rotas devem e não devem ser indexadas
Structured Data	JSON-LD com schema.org para Organization, Product, FAQPage, BreadcrumbList
Open Graph / Twitter Cards	Meta tags dinâmicas para compartilhamento em redes sociais
Canonical URLs	Evita conteúdo duplicado em rotas com parâmetros diferentes
Hreflang	Tags de idioma para versões internacionais do site
Lazy Loading	Imagens e componentes pesados carregam sob demanda
Compressão	Brotli/Gzip via CDN, imagens em formato WebP/AVIF

6.2 SEO de Conteúdo (Responsabilidade do Marketing / SEO Specialist)

- Pesquisa de palavras-chave: ferramentas Semrush, Ahrefs, Google Keyword Planner
- Estratégia de conteúdo: blog, landing pages, cases de sucesso, documentação pública
- Link building: parcerias, guest posts, PR digital
- Monitoramento mensal: posições no SERP, tráfego orgânico, taxa de cliques (CTR)
- Auditoria trimestral: verificação de links quebrados, páginas com alto bounce, canibalização

7. Compliance — LGPD e Privacidade de Dados

7.1 Base Legal para Tratamento de Dados

Todo tratamento de dados pessoais no sistema é fundamentado em uma das bases legais previstas pelo Art. 7 da LGPD. As bases utilizadas são documentadas no Registro de Atividades de Tratamento (RAT).

Base Legal	Uso no Sistema
Consentimento	Newsletter, cookies de marketing, comunicações opcionais
Execução de contrato	Dados necessários para prestar o serviço contratado
Legítimo interesse	Análise de uso do produto (analytics), prevenção a fraudes
Obrigação legal	Retenção de dados fiscais e contábeis conforme legislação

7.2 Direitos dos Titulares — Implementação Técnica

- Acesso: endpoint GET /privacy/my-data retorna todos os dados do usuário em JSON
- Retificação: painel de conta permite edição de dados cadastrais
- Exclusão: workflow de 'direito ao esquecimento' — anonimização em 30 dias
- Portabilidade: export dos dados em formato CSV/JSON via painel
- Revogação de consentimento: toggle em preferências de comunicação

7.3 Medidas Técnicas de Proteção

- Pseudonimização de PII em logs e ambientes de staging
- Data minimization: apenas campos estritamente necessários são coletados
- Retenção definida: dados inativos eliminados automaticamente após 5 anos
- DPO (Data Protection Officer) designado e canal de contato publicado
- DPIA (Avaliação de Impacto) realizada para novos tratamentos de alto risco

8. Manutenção e Operação Contínua

8.1 Ciclo de Releases

Tipo	Frequência e Critério
Hotfix (P1/P2)	Imediato — branch direta de main, processo acelerado de revisão e deploy
Patch (P3)	Semanal — agrupa correções de bugs e pequenas melhorias
Minor release	Quinzenal (sprint de 2 semanas) — novas funcionalidades e melhorias
Major release	Trimestral — mudanças arquiteturais, breaking changes com migration guide

8.2 Gestão de Dependências

- Dependabot configurado para abrir PRs automáticos de atualização semanalmente
- Renovate Bot para atualização coordenada de dependências com testes automáticos
- Review mensal do changelog de dependências críticas (frameworks, ORMs, libs de auth)
- Política: sem dependências com CVE crítico ou alto não resolvido em produção

8.3 Backup e Disaster Recovery

Recurso	Estratégia
Banco de dados PostgreSQL	Backup automático diário (AWS RDS Automated Backups) + WAL archiving contínuo
Arquivos (S3)	Replicação cross-region automática + versionamento de objetos habilitado
Secrets e configs	AWS Secrets Manager com replicação multi-region
RTO (Recovery Time Objective)	< 4 horas para incidentes críticos
RPO (Recovery Point Objective)	< 1 hora de perda máxima de dados

8.4 Documentação Técnica Contínua

- README atualizado a cada sprint com instruções de setup e variáveis de ambiente
- OpenAPI (Swagger) gerado automaticamente pelo backend — sempre sincronizado com o código
- ADRs (Architecture Decision Records) para registrar decisões arquiteturais importantes
- Runbooks para incidentes comuns — disponíveis no Notion / Confluence

- Onboarding guide para novos membros do time — ambiente pronto em < 30 minutos

KPIs de Saúde do Sistema
• Uptime: meta >= 99.9% mensal (máx. 43 min de downtime/mês)
• Latência P95 da API: < 300ms para todas as rotas críticas
• Taxa de erro (5xx): < 0.1% do total de requisições
• Cobertura de testes: >= 80% nas camadas de domínio e aplicação
• Time to Deploy: < 15 minutos do merge ao produção
• MTTR (Mean Time to Recovery): < 2 horas para incidentes P1

9. Roadmap e Fases do Projeto

9.1 Fases de Desenvolvimento

Fase	Entregáveis
Fase 1 — Fundação (Meses 1-2)	Design system, autenticação, estrutura base do CRM, CI/CD pipeline
Fase 2 — CRM Core (Meses 3-4)	Gestão de leads, contatos, oportunidades, pipeline de vendas, dashboards
Fase 3 — Site Público (Mês 5)	Landing pages otimizadas para SEO, blog, formulários de captação
Fase 4 — Automações (Mês 6)	E-mails automáticos, webhooks, integrações (WhatsApp, ERP)
Fase 5 — Analytics (Mês 7)	Relatórios avançados, exportações, BI embeddo
Fase 6 — Escala (Mês 8+)	Performance tuning, expansão de integrações, mobile app

9.2 Critérios de Aceite por Entregável

- Todos os testes automatizados passando (unitários, integração, e2e)
- Code review aprovado por pelo menos 2 engenheiros sênior
- Documentação técnica atualizada (OpenAPI, README, ADR se aplicável)
- Testes de aceitação validados pelo Product Manager
- Performance validada: LCP e API latency dentro dos targets
- Sem vulnerabilidades críticas ou altas no SAST/dependency scan

10. Glossário Técnico

Termo	Definição
ADR	Architecture Decision Record — registro documentado de uma decisão técnica importante
DAST	Dynamic Application Security Testing — teste de segurança em aplicação em execução
DBA	Database Administrator — responsável pela gestão e otimização do banco de dados
DPIA	Data Protection Impact Assessment — avaliação de impacto à proteção de dados (LGPD)
JWT	JSON Web Token — padrão para autenticação stateless via tokens assinados
LGPD	Lei Geral de Proteção de Dados Pessoais — Lei nº 13.709/2018 (Brasil)
MFA	Multi-Factor Authentication — autenticação com mais de um fator de verificação
MTTR	Mean Time to Recovery — tempo médio para recuperação após um incidente
OWASP	Open Web Application Security Project — organização de referência em segurança web
RBAC	Role-Based Access Control — controle de acesso baseado em papéis/funções
RPO	Recovery Point Objective — ponto máximo de perda de dados tolerado após desastre
RTO	Recovery Time Objective — tempo máximo tolerado para recuperação do sistema
SAST	Static Application Security Testing — análise estática de segurança no código-fonte
SLA	Service Level Agreement — acordo de nível de serviço com métricas e penalidades
SPA	Single Page Application — aplicação web com navegação sem recarregamento de página
SRE	Site Reliability Engineering — prática de operação de sistemas com foco em confiabilidade
SSG	Static Site Generation — geração antecipada de HTML para máxima performance e SEO
SSR	Server-Side Rendering — renderização de HTML no servidor para cada requisição
WAL	Write-Ahead Log — registro de todas as modificações no banco, base para backups contínuos